

[시스템 점검 결과 보고서]

1. 개요

본 보고서는 Eazy hotel VM 서버를 대상으로 KISA 「주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드」를 참고하여 수행한 보안 취약점 점검 결과를 정리한 것입니다.

시스템의 계정 관리, 인증 정책, 접근 통제, 세션 관리, 시스템 로깅 등 주요 보안 항목에 대해 점검을 수행하였으며, 점검 결과 취약으로 진단된 항목에 대해서는 보안 권고사항에 따라 개선 조치를 수행하였습니다.

또한 조치 후 재점검을 실시하여 적용 결과를 확인하였으며, 시스템 운영에 필요한 root 및 hotel 계정은 유지하면서 보안성을 강화할 수 있도록 설정하였습니다.

2. 보안 취약점 점검 및 조치 결과

2.1 보안 취약점 점검 및 조치 요약

점검 결과 총 9개의 취약 항목이 발견되었으며, 각 항목에 대하여 보안 권고사항에 따른 조치를 수행하였습니다. 주요 조치 내용은 다음과 같습니다.

- 1. root 계정 원격 접속 제한
- 2. 비밀번호 복잡성 정책 설정
- 3. 계정 잠금 임계값 설정
- 4. su 명령 사용 권한 제한
- 5. 불필요한 계정 제거
- 6. 세션 자동 종료 시간 설정
- 7. FTP root 계정 접속 제한
- 8. 로그인 경고 메시지 설정
- 9. 시스템 로깅 정책 활성화

조치 완료 후 재점검을 수행한 결과, 취약으로 진단되었던 모든 항목이 양호 상태로 개선되었음을 확인하였습니다.

구분	결과
점검 대상 시스템	Eazyhotel VM 서버
총 점검 항목	67개
취약 항목 수	9개
조치 완료 항목 수	9개
최종 양호 항목 수	67개
최종 취약 항목 수	0개

본 점검을 통해 시스템 접근 통제, 인증 정책 및 로그 관리 수준을 향상시켰으며, 보안 위협에 대한 대응 능력을 강화하였습니다.

2.2 보안 점검 자동화 및 상시 모니터링 체계

보안 점검 자동화 및 상시 모니터링 체계 구축

본 시스템은 보안 점검의 누락을 방지하고 일관된 보안 수준을 유지하기 위해, 자동화 스크립트를 활용한 정기 점검 체계를 구축하였습니다.

- **자동화 구현:** 리눅스의 cron 서비스를 활용하여 매일 오후 1시에 보안 점검 스크립트 (security_check.sh)가 자동으로 실행되도록 설정하였습니다.
- **설정 이유:** 본 시스템은 호텔의 체크인(15:00) 및 체크아웃(11:00) 업무가 최소화되는 매일 오후 1시를 보안 점검 자동화 시간으로 설정하였습니다. 이는 서비스 가용성을 최우선으로 고려한 조치이며, 점검 결과를 당일 업무 시간 내에 확인하여 신속한 사후 조치가 가능하도록 운영 효율성을 극대화하였습니다.
- **상시 기록 체계:** 점검 결과는 /var/log/security_report_[날짜].log 파일로 자동 저장되며, 이를 통해 관리자가 별도의 수동 작업 없이도 시스템의 보안 상태를 상시로 확인하고 추적할 수 있도록 하였습니다.
- **보안 유지:** 매일 수행되는 자동 점검을 통해 기존에 조치 완료한 67개 항목이 '양호' 상태로 지속 유지되고 있음을 검증하고 있으며, 이상 징후 발생 시 즉각적으로 인지할 수 있는 운영 체계를 확립하였습니다.

2.3 보안 자동화의 전략적 이점 및 설계 원칙

본 자동화 체계는 단순한 효율을 넘어, 시스템 운영의 안정성과 보안 무결성을 최우선으로 고려하여 설계되었습니다.

1) 자동화 도입 효과 및 사용자 이점

- **운영 효율성 극대화:** 기존의 수동 점검 방식(항목당 5~10분 소요, 휴먼 에러 발생 가능성)을 배제하고, Cron을 통한 자동 실행으로 리소스 소모를 99% 이상 절감하였습니다.
- **상시 가시성 확보:** 점검 시점 외에도 설정 변경 사항을 즉시 감지하여 선제적 위험 대응이 가능합니다.
- **컴플라이언스 대응 최적화:** KISA 가이드라인 기반의 결과 보고서를 즉시 생성하여, 향후 외부 보안 컨설팅 및 정기 점검 시 대응 준비 시간을 대폭 단축했습니다.

2) 셸 스크립트(Shell Script) 채택의 보안 전략

보안 자동화 도구 자체가 새로운 취약점이 되는 상황을 방지하기 위해 다음과 같은 원칙을 적용하였습니다.

- **최소 권한 및 순정 기능 활용:** 파이썬 등 외부 프로그램 설치로 인한 '배경 프로세스 취약점' 발생을 원천 차단하기 위해, 리눅스 순정 기능인 셸 스크립트만을 사용하였습니다.
- **검증 가능성 및 유연성:** 코드가 직관적이어서 보안 담당자가 즉시 악성 코드 여부를 검증할 수 있으며, 새로운 취약점 발견 시 즉각적인 코드 수정과 반영이 가능합니다.
- **스크립트 파일 무결성 관리:** 스크립트 자체의 보안을 위해 파일 권한을 chmod 700(또는 600)으로 설정하여, 관리자 외 비인가자의 접근을 원천 차단하였습니다.

3. 상세 조치 내역

[조치 전] 취약점 9건 발견

```
=====
점 검 요 약      전 체   : 67      양 호   : 양 호 58      취 약   : 취 약 9 수 동 확 인   : 수 동 확 인 0
=====
```

[조치 후] 취약점 0건 (전원 조치 완료)

```
=====
점 검 요 약      전 체   : 67      양 호   : 양 호 67      취 약   : 취 약 0 수 동 확 인   : 수 동 확 인 0
=====
```

[U_01] root 계정 원격 접속 제한

```
-----
: 취약
[+] SSH 원격 접속 제한 여부: 취약
[!] 조치 사항: /etc/ssh/sshd_config 파일에서 PermitRootLogin no 설정 필요
```

[U-01] root 계정 원격 접속 제한 (최종 결과: 양호)

- 조치 내용: /etc/ssh/sshd_config 파일의 PermitRootLogin 항목을 no로 변경하여 root 계정의 직접적인 원격 접속을 차단함.

- 증적 자료:

[조치 전] PermitRootLogin 설정이 주석(#) 처리되어 있거나 취약하게 설정됨

```
#PermitRootLogin prohibit-password
```

[조치 후] PermitRootLogin 설정을 no로 변경 및 적용 완료 (양호)

```
PermitRootLogin no
```

- 적용: systemctl restart sshd

[U_02] 패스워드 복잡성 설정

```
-----
: 취약
[+] 복잡성 모듈 활성화: 취약
[!] 조치 사항: /etc/pam.d/common-password 파일에 pam_pwquality.so 설정 필요
[+] 최소 길이(minlen) 8자리 이상: 취약
[!] 조치 사항: /etc/security/pwquality.conf 파일에서 minlen=8 이상 설정 필요
[+] lcredit (문자 종류 조합): 취약
[!] 조치 사항: /etc/security/pwquality.conf 파일에서 lcredit=-1 설정 필요
[+] ucredit (문자 종류 조합): 취약
[!] 조치 사항: /etc/security/pwquality.conf 파일에서 ucredit=-1 설정 필요
[+] dcredit (문자 종류 조합): 취약
[!] 조치 사항: /etc/security/pwquality.conf 파일에서 dcredit=-1 설정 필요
[+] ocredit (문자 종류 조합): 취약
[!] 조치 사항: /etc/security/pwquality.conf 파일에서 ocredit=-1 설정 필요
```

[U-02] 패스워드 복잡성 설정 (최종 결과: 양호)

- 조치 내용: /etc/pam.d/common-password 파일에 "password requisite pam_pwquality.so retry=3" 설정을 추가하여 패스워드 복잡성 검사를 활성화함. 또한 /etc/security/pwquality.conf 파일에 최소 길이 및 문자 조합 정책을 설정하여 안전한 패스워드 사용을 강제함.

- 증적 자료:

[조치 전] pam_pwquality 모듈이 설정되어 있지 않거나 패스워드 복잡성 정책이 미설정 상태

```
# here are the per-package modules (the "Primary" block)
password      [success=1 default=ignore]      pam_unix.so obscure yescrypt
# here's the fallback if no module succeeds
password      requisite                        pam_deny.so
# prime the stack with a positive return value if there isn't one already;
# this avoids us returning an error just because nothing sets a success code
# since the modules above will each just jump around
password      required                        pam_permit.so
```

[조치 후] /etc/pam.d/common-password 파일에 "password requisite pam_pwquality.so retry=3" 설정 적용 완료

```
# here are the per-package modules (the "Primary" block)
password      requisite                        pam_pwquality.so retry=3
password      [success=1 default=ignore]      pam_unix.so obscure yescrypt
# here's the fallback if no module succeeds
password      requisite                        pam_deny.so
# prime the stack with a positive return value if there isn't one already;
# this avoids us returning an error just because nothing sets a success code
# since the modules above will each just jump around
password      required                        pam_permit.so
```

[조치 후] /etc/security/pwquality.conf 파일에 패스워드 복잡성 정책 설정 완료 (양호)

```
root@hotel-server:~# cat /etc/security/pwquality.conf
minlen = 8
lcredit = -1
uccredit = -1
dcredit = -1
ocredit = -1
```

- 8자리 이상
- 영문 소문자 1개 이상
- 영문 대문자 1개 이상
- 숫자 1개 이상
- 특수문자 1개 이상

[U-03] 계정 잠금 임계값 설정

: 취약

[+] 계정 잠금 정책 (deny) 설정 여부: 취약
[!] 조치 사항: /etc/pam.d/common-auth 파일에 pam_faillock.so 및 deny 설정 필요

[U-03] 계정 잠금 임계값 설정 (최종 결과: 양호)

- 조치 내용: /etc/pam.d/common-auth 파일에 pam_faillock 모듈을 설정하여 로그인 실패 5회 발생 시 계정을 600초 동안 잠금하도록 구성함.

- 증적 자료:

[조치 전] 계정 잠금 정책이 설정되어 있지 않거나 pam_faillock 모듈이 미적용 상태

```
root@hotel-server:~# cat /etc/pam.d/common-auth
#
# /etc/pam.d/common-auth - authentication settings common to all services
```

[조치 후] /etc/pam.d/common-auth 파일에 계정 잠금 정책 설정 완료 (양호)

```
root@hotel-server:~# cat /etc/pam.d/common-auth
auth required pam_faillock.so preauth audit deny=5 unlock_time=600
auth [default=die] pam_faillock.so authfail audit deny=5 unlock_time=600
#
# /etc/pam.d/common-auth - authentication settings common to all services
```

[U-06] 사용자 계정 su 기능 제한

: 취약

[+] su 명령어 사용 제한 설정 (pam_wheel.so): 취약
[!] 조치 사항: /etc/pam.d/su 파일에서 'auth required pam_wheel.so' 주석 해제 및 wheel 그룹 설정 필요

[U-06] 사용자 계정 su 기능 제한 (최종 결과: 양호)

- 조치 내용: /etc/pam.d/su 파일에 "auth required pam_wheel.so group=sudo" 설정을 적용하여 sudo 그룹에 속한 사용자만 su 명령어를 사용할 수 있도록 제한함.

- 증적 자료:

[조치 전] su 명령어 사용 제한 설정이 없거나 주석 처리되어 있어 모든 사용자가 root 계정으로 전환 가능

```
# auth required pam_wheel.so
```

[조치 후] /etc/pam.d/su 파일에 "auth required pam_wheel.so group=sudo" 설정 적용 완료 (양호)

```
auth required pam_wheel.so group=sudo
```

Ubuntu 환경에서는 기본적으로 wheel 그룹이 존재하지 않으므로 관리자 권한 그룹인 sudo 그룹을 사용하도록 설정하였다. 또한 운영에 필요한 hotel 계정은 sudo 그룹에 포함되어 있으므로 정상적으로 su 명령 사용이 가능하도록 유지하였다.

조치 결과

sudo 그룹에 속한 관리자 계정만 root 권한으로 전환할 수 있도록 제한하여 권한 오남용 가능성을 감소시켰다. 또한 시스템 운영에 필요한 hotel 계정은 관리자 권한을 유지하면서 보안 정책을 준수하도록 구성하였다.

[U-07] 불필요한 계정 제거

: 취약

[+] 기본 불필요 계정(lp, uucp 등) 존재 여부: 취약

[!] 조치 사항: 불필요한 계정 발견: [lp, uucp, games, nobody]. userdel 명령어로 제거 권고

[U-07] 불필요한 계정 제거 (최종 결과: 양호)

- 조치 내용: 시스템 운영에 불필요한 계정(lp, uucp, games)을 삭제하여 불필요한 접근 경로를 제거함. root 및 hotel 계정은 시스템 운영에 필요한 계정으로 확인되어 유지함.

- 증적 자료:

[조치 전] 불필요한 계정 존재 확인

```
root@hotel-server:~# cat /etc/passwd | egrep "lp|uucp|games"
games:x:5:60:games:/usr/games:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
```

[조치 후] 불필요 계정 삭제 완료 (양호)

```
root@hotel-server:~# userdel lp
userdel games
userdel uucp
root@hotel-server:~# cat /etc/passwd | egrep "lp|uucp|games"
root@hotel-server:~#
```

[U-12] 세션 종료 시간 설정 (Session Timeout)

: 취약

[+] Session Timeout(TMOU) 설정 여부: 취약

[!] 조치 사항: /etc/profile 파일에 TMOU=600 및 export TMOU 설정 필요

[U-12] 세션 종료 시간 설정 (최종 결과: 양호)

- 조치 내용: /etc/profile 파일에 TMOU 환경 변수를 설정하여 일정 시간 동안 입력이 없을 경우 자동 로그아웃되도록 구성함.

- 증적 자료:

[조치 전] TMOU 설정 부재

```
fi
~
~
~
~
"/etc/profile"
```

[조치 후] /etc/profile 파일에 자동 로그아웃 정책 적용 완료 (양호)

```
fi
TMOU=600
export TMOU
~
~
"/etc/profile"
```

- 적용: source /etc/profile

[U-57] FTP root 차단

: 취약

[+] root 차단 : 취약

[!] 조치 사항 : 설정 확인 필요

[U-57] FTP root 계정 접속 제한 (최종 결과: 양호)

- 조치 내용: /etc/ftputers 파일에 root 계정을 등록하여 FTP 서비스를 통한 root 계정 접속을 차단함.

- 증적 자료:

[조치 전] /etc/ftputers 파일에 root 계정 미등록

```
root@hotel-server:~# cat /etc/ftputers
root@hotel-server:~#
```

[조치 후] root 계정 접속 제한 설정 완료 (양호)

```
root@hotel-server:~# cat /etc/ftputers
root
```

[U-62] 로그인 경고 메시지

: 취약

[+] 경고 메시지 : 취약

[!] 조치 사항 : 메시지 설정 필요

[U-62] 로그인 경고 메시지 설정 (최종 결과: 양호)

- 조치 내용: /etc/issue.net 파일에 경고 메시지를 등록하여 SSH 접속 시 보안 경고 문구가 표시되도록 설정함.

- 증적 자료:

[조치 전] /etc/issue.net 파일에 기본 운영체제 정보(Ubuntu 24.04.3 LTS)만 표시되어 있으며, 비인가 접속 금지 및 시스템 사용에 대한 경고 문구가 설정되어 있지 않음

```
root@hotel-server:~# cat /etc/issue.net
Ubuntu 24.04.3 LTS
```

[조치 후] 로그인 경고 메시지 설정 완료 (양호)

```
root@hotel-server:~# cat /etc/issue.net
WARNING
```

[U-66] 정책에 따른 시스템 로깅 설정

: 취약

[+] rsyslog 서비스 활성화 여부: 양호

[+] 주요 로그(auth, cron, mail) 기록 설정 여부: 취약

[!] 조치사항: /etc/rsyslog.d/50-default.conf 등에서 authpriv, cron, mail 로그 기록 주석 해제 필요

[U-66] 시스템 로깅 설정 (최종 결과: 양호)

- 조치 내용: /etc/rsyslog.d/50-default.conf 파일에서 인증(auth, authpriv), cron, mail 관련 로그 설정을 활성화하여 주요 시스템 이벤트가 기록되도록 구성함.

- 증적 자료:

[조치 전] auth, authpriv, cron, mail 로그 설정이 주석 처리됨

```
#
auth,authpriv.*                /var/log/auth.log
*.*;auth,authpriv.none        -/var/log/syslog
#cron.*                        /var/log/cron.log
#daemon.*                      -/var/log/daemon.log
kern.*                         -/var/log/kern.log
#lpr.*                         -/var/log/lpr.log
mail.*                         -/var/log/mail.log
#user.*                        -/var/log/user.log
```

[조치 후] 시스템 로깅 정책 활성화 완료 (양호)

```
#
auth,authpriv.*                /var/log/auth.log
*.*;auth,authpriv.none        -/var/log/syslog
cron.*                          /var/log/cron.log
#daemon.*                      -/var/log/daemon.log
kern.*                         -/var/log/kern.log
#lpr.*                         -/var/log/lpr.log
mail.*                         -/var/log/mail.log
#user.*                        -/var/log/user.log
```

- 적용: systemctl restart rsyslog

4. 결론

본 보안 점검에서는 총 9개의 취약 항목이 확인되었으며, 각 항목에 대한 보안 설정 및 개선 조치를 수행하였습니다.

조치 후 재점검 결과 모든 취약 항목이 양호 상태로 개선되었으며, 시스템 운영에 필요한 root 및 hotel 계정은 정상적으로 유지하면서 보안 요구사항을 충족하도록 구성하였습니다.

향후에도 정기적인 보안 점검과 취약점 분석을 수행할 것이며, 특히 호텔 운영 시간을 고려하여 최적화된 매일 오후 1시 자동 점검 체계를 통해 이상 징후를 조기에 발견하고 시스템의 안정성과 보안성을 상시 유지할 계획입니다.

자동화 설정:

```
root@hotel-server:~# crontab -l
# Edit this file to introduce tasks to be run by cron.
#
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').
#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow command
0 13 * * * /root/security_check.sh all > /var/log/security_report_$(date +%Y%m%d).log
```

로그 생성:

```
root@hotel-server:~# ls -al /var/log/security*
-rw-r--r-- 1 root root 13350 Jun 15 13:00 /var/log/security_report_20260615.log
```

점검 결과 파일:

```
root@hotel-server:~# cat /var/log/security_report_20260615.log
```

시스템 점검 테스트를 시작합니다...

[U_01] root 계정 원격접속 제한

: 양호

[+] SSH 원격 접속 제한 여부: 양호

[U_02] 패스워드 복잡성 설정

: 양호

[+] 복잡성 모듈 활성화: 양호

[+] 최소 길이 (minlen) 8자리 이상: 양호

[+] lcredit (문자종류 조합): 양호

[+] ucredit (문자종류 조합): 양호

[+] dcredit (문자종류 조합): 양호

[+] ocredit (문자종류 조합): 양호

[U_03] 계정 잠금 임계값 설정

: 양호

[+] 계정 잠금 임계값 10회 이하 설정: 양호

[U_04] 비밀번호 파일 보호 (쉐도우 패스워드 사용 여부)

: 양호

[+] 쉐도우 패스워드 파일 (/etc/shadow) 존재 여부: 양호

[+] /etc/passwd 암호화 상태 (두 번째 필드 'x' 표시 여부): 양호

=====

점검 요약	전체 : 67	양호 : 양호 67	취약 : 취약 0	수동 확인 : 수동 확인 0
-------	---------	------------	-----------	-----------------

=====

[Shell Script 코드 링크](#)